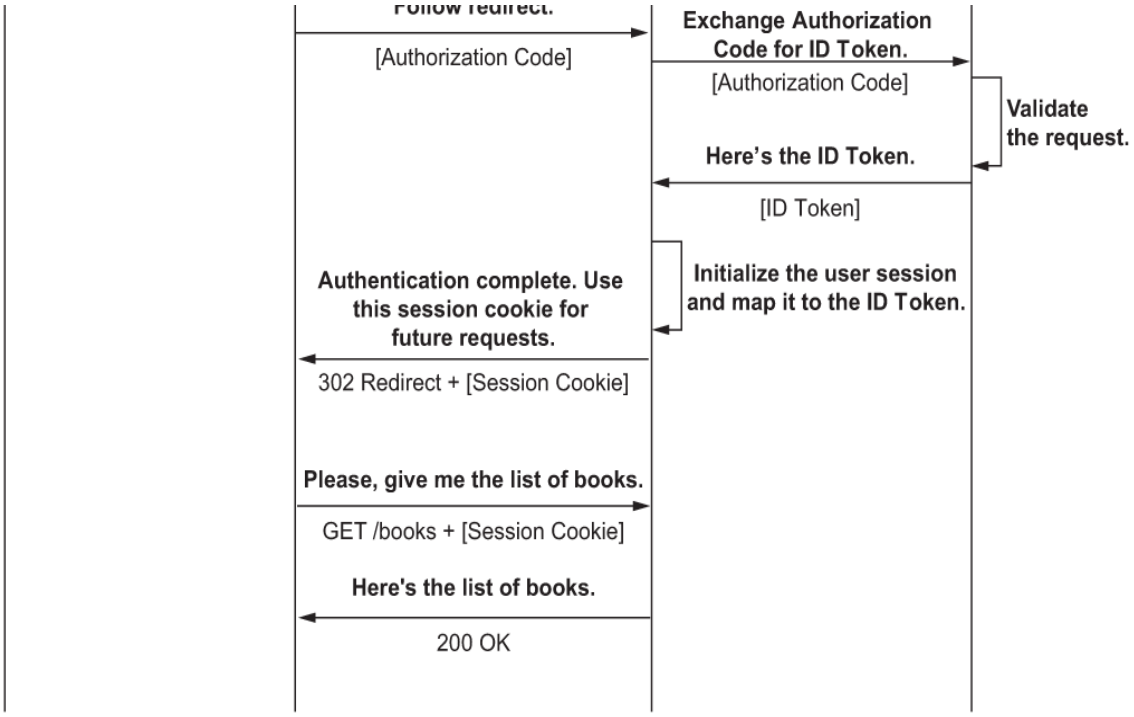


Figure 11.3 The authentication flow supported by the OIDC protocol

When adopting the authentication flow illustrated in figure 11.3, Edge Service is not affected by the specific authentication strategy. We could configure Keycloak to use an Active Directory or perform a social login via GitHub, and Edge Service would not require any changes. It only needs to support OIDC to verify that the authentication happened correctly and get information about the user via an ID Token. What's an ID Token? It's a *JSON Web Token* (JWT) containing information about the user authentication event. We'll take a closer look at JWTs in the next section.

NOTE Whenever I mention OIDC, I am referring to the OpenID Connect Core 1.0 specification (https://openid.net/specs/openid-connect-core-1_0.xhtml). Whenever I mention OAuth2, unless specified otherwise, I am referring to the OAuth 2.1 specification currently under standardization (https://oauth.net/2.1) and meant to replace the OAuth 2.0 standard described in RFC 6749 (https://tools.ietf.org/html/rfc6749).

11.3.2 Exchanging user information with JWT